

CPRE 4310

M08 HW

Assignments will be submitted in PDF format via Canvas.

Please submit your homework online through Canvas. Late homework will not be accepted.

Important: Your submission must be in .pdf format ONLY!

1. Consider the following threats to Web security and describe how each is countered by a particular feature of SSL.

- a. Man-in-the-middle attack: An attacker interposes during key exchange, acting as the client to the server and as the server to the client.

During MiTM attacks, if we have implemented SSL for our communication, a feature that this gives us access to is the use of Digital Certificates using a trusted Certificate Authority (CA). Using a trusted CA ensures that we are communicating with the “real” server and not an attacker. This happens by the Server confirming its identity with a trusted 3rd party CA which then issues the server with a digital certificate by signing relevant info. Then the server sends its digital certificate that it got from the CA to the client, who can then verify this certificate by using the Public Key of the CA. Basically, this prevents MiTM attacks because an attacker cannot replicate the digital certificate that is signed by the CA’s private key.

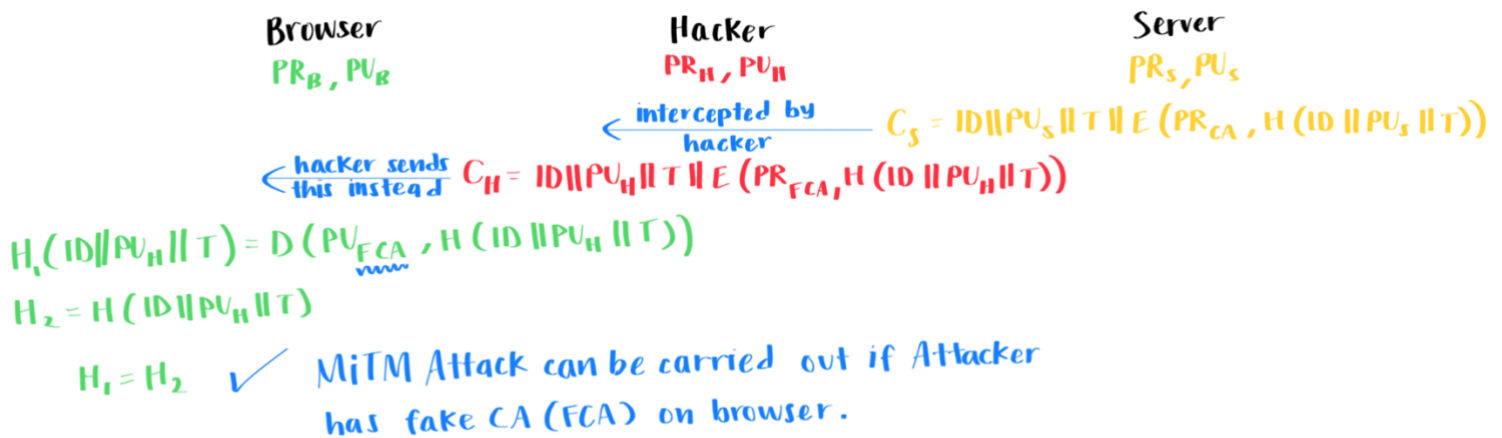
- b. Password sniffing: Passwords in HTTP or other application traffic are eavesdropped.

SSL is able to counter any application traffic and passwords in HTTP communications from being seen using for all the application data being sent. In HTTP the traffic is sent through GET, POST, and other requests which can be eavesdropped using Wireshark or tcpdump. Whereas, if we use HTTPS we are able to communicate between devices with the data being encrypted. This means even if an attacker is able to eavesdrop and view our packets, he will not be able to decipher what it is saying.

2. What is X.509 Certificate?

X.509 is a certificate format that includes the version of the certificate, a serial number that is unique to the CA, a signature algorithm, CA’s name and unique identifier, and the validity period. Additionally, it also includes the subject’s name and unique identifier, public key info (ex: algorithm, parameters, key), and key.

- Assume that a hacker was able to install a fake Certificate Authority (CA) signature on your browser. Aided with drawing (similar to the drawing in the lecture's slides), show how the Man in The Middle (MiTM) Attack can be carried out even if the server is using a certificate signed by the original CA.



With the above, as we can see, if the browser has a Fake CA that it trusts then the entire process will fail. This is because even though the Server is sending the correct cipher with the message encrypted by the Private Key of the Real CA, the Hacker intercepts this message and modifies it to use the Private Key of the Fake CA and his own Public Key instead. When this is verified by the browser, it will use the Fake CA's public key to decrypt the message and will think it is the real server that it is communicating with.